

CBTIS-246

ALUMNO=DIEGO.M.C

MATERIA: ICSDSI

2 "I"

PRESENTACION:TEMAS

IMPORTANTES SOBRE PHYTON

TEMAS DE VITAL IMPORTANCIA EN CIBERSEGURIDAD CON PYTHON

1.

- **Gestión de dependencias:** Supervisión y actualización estricta de bibliotecas para evitar el uso de paquetes vulnerables.

2.

- **Manejo de secretos:** Almacenamiento seguro de credenciales y claves mediante variables de entorno, evitando dejarlas expuestas en el código fuente.

3.

- **Manejo de secretos:** Almacenamiento seguro de credenciales y claves mediante variables de entorno, evitando dejarlas expuestas en el código fuente.

4.

- **Validación de entradas y saneamiento de datos:** Comprobación rigurosa y limpieza de cualquier información proporcionada por el usuario antes de procesarla.

5.

- **Principio de menor privilegio:** Otorgar a tu código y usuarios únicamente los permisos mínimos necesarios para realizar sus funciones.

6.

- **Actualización del entorno:** Mantener Python y todas sus dependencias en sus versiones más recientes para asegurar la aplicación de parches de seguridad.

TIPOS DE ATAQUES COMUNES EN PYTHON



- Inyección de código: Ejecución maliciosa de comandos arbitrarios a través de funciones peligrosas.
- Secuestro de tipografía (Typosquatting): Infección de entornos por la instalación accidental de librerías maliciosas que tienen nombres muy similares a paquetes legítimos.
- Ataques de día cero (Zero-Day) en librerías: Explotación de vulnerabilidades recientemente descubiertas (y aún sin parche oficial) en paquetes de terceros.
- Deserialización insegura: Ejecución de código arbitrario al cargar o deserializar datos que no son de confianza utilizando librerías como pickle.
- Inyección SQL: Manipulación de consultas a bases de datos a través de entradas no saneadas para extraer o alterar información confidencial.
- Inyección de comandos: Ejecución de comandos del sistema operativo subyacente a través de aplicaciones web vulnerables.

¿QUÉ ES LA INGENIERÍA SOCIAL?

La ingeniería social es una técnica de manipulación psicológica que utilizan los atacantes para engañar a los usuarios y lograr que revelen información confidencial, instalen software malicioso o entreguen acceso a sistemas restringidos. En lugar de atacar directamente un sistema informático, el atacante explota el error, la confianza o la falta de conocimiento humano.

- **POSIBLES TÍTULOS PARA TU ARTÍCULO O PRESENTACIÓN**

- **DE LA VULNERABILIDAD AL BLINDAJE: SEGURIDAD ESENCIAL EN PYTHON**
- **EL ESLABÓN MÁS DÉBIL: CÓDIGO SEGURO Y EL IMPACTO DE LA INGENIERÍA SOCIAL**
- **EL CÓDIGO NO ESTÁ SOLO: PROTEGIENDO APLICACIONES PYTHON CONTRA ATAQUES MODERNOS**
- **ANATOMÍA DE LAS VULNERABILIDADES EN PYTHON Y DEFENSA DEL FACTOR HUMANO [1]**

Para complementar estas prácticas, puedes apoyarte en guías de organizaciones especializadas, como revisar las recomendaciones de desarrollo seguro de Black Duck o las directrices de Kiuwan.

VARIANTES DE PHISHING (SUPLANTACION DE IDENTIDAD)



PHISHING TRADICIONAL

- Correos electrónicos masivos que simulan ser de bancos o servicios conocidos con enlaces a páginas web fraudulentas.

SPEAR PHISHING

- Ataque altamente dirigido. Investiga a la víctima para personalizar el mensaje y hacerlo parecer confiable.

WHALING (PESCA DE BALLENAS)

- Phishing enfocado en altos ejecutivos o personas con gran poder de decisión en una empresa.

SMISHING

- Fraudes que utilizan mensajes de texto (SMS) para engañar al usuario.

VISHING

- Suplantación de identidad a través de llamadas telefónicas



ENGAÑOS Y MANIPULACIÓN DIRECTA



- **BAITING (SEÑUELO):** USO DE FALSAS PROMESAS (PREMIOS, DESCARGAS GRATUITAS) PARA ATRAER A LA VÍCTIMA A INSTALAR UN MALWARE O REVELAR DATOS.
- **PRETEXTING:** CREACIÓN DE UN ESCENARIO O HISTORIA INVENTADA Y CONVINCENTE POR PARTE DEL ATACANTE PARA GANARSE LA CONFIANZA Y EXTRAER INFORMACIÓN.
- **QUID PRO QUO:** OFRECER UN SERVICIO O AYUDA A CAMBIO DE INFORMACIÓN CONFIDENCIAL O ACCESO A LOS SISTEMAS.
- **TAILGATING (COLARSE):** ACCESO FÍSICO NO AUTORIZADO A UN EDIFICIO O ÁREA RESTRINGIDA, APROVECHANDO EL DESCUIDO DE UN EMPLEADO PARA SEGUIRLO DE CERCA.



ESTAFAS DE IDENTIDAD Y REDES



BUSINESS EMAIL COMPROMISE (BEC)

- Compromiso del correo electrónico corporativo. El atacante suplanta la identidad de un ejecutivo o proveedor para desviar transferencias bancarias o pagos a cuentas fraudulentas.

CATFISHING / ROMANCES FALSOS

- Uso de perfiles falsos en redes sociales o aplicaciones de citas para manipular emocionalmente a la víctima con fines de extorsión o fraude económico.

SCAREWARE

- Software de seguridad falso o alertas emergentes alarmantes. Se utiliza para asustar al usuario y convencerlo de comprar un programa inútil o descargar malware

